

Phishing: Anatomy & Detection

The Phishing Chain

- Lure** – the channel: email, SMS (smishing), voice (vishing), QR (quishing), DM
- Hook** – the bait: an urgent message + a clickable something
- Payload** – the link to a fake login, or an attachment macro
- Exploitation** – credentials stolen, session hijacked, malware dropped
- Follow-up** – attacker uses the captured access

Reading a Phishing Email (Analyst Style)

Check in order:

Check	Where	Red Flag
Sender	<code>from</code> header + <code>reply-to</code>	spoofed or foreign address; some other reply-to
Domain	DKIM/SPF/DMARC	Fail = not from the claimed org
Subject	urgency language	"URGENT", "Your account is locked"
Recipient	<code>To</code> vs <code>Bcc</code> blast	You're part of a mass send
Link target	HOVER (don't click)	<code>paypal.com</code> or <code>bit.ly/xxx</code>
Attachment	extension + scanner	<code>.docm</code> , <code>.zip</code> + <code>.exe</code> , macro-enabled

Email Authentication: SPF, DKIM, DMARC

- SPF** – DNS record listing authorized mail servers for a domain
- DKIM** – domain signs email with a cryptographic key

DMARC – policy on what to do with failing mail + reporting

```
# Check the auth headers of a FRIEND's legitimate mail = the baseline
# (In Gmail: Show original / View source)
```

Defender job: a properly configured DMARC policy is a *receiving* kill-switch that prevents 90% of spoofing.

The Elevation-of-Privilege Inside Phishing

Modern phishing is surgical:

Credential phishing – exact clone of the login page

MFA relay – real-time passport problem: "I'm stealing a session, not a password"

BEC (Business Email Compromise) – fake invoice, wire transfer, HR doc

Detection Playbook for a SOC

Does the email claim to come from a domain with DMARC=reject, but no DKIM? → likely spoof

Does the link resolve to a recently registered domain? → recently-registered = platform option flagged

Attach a sandbox URL scanner on suspicious links

If a user submits it via "Report phishing" → triage quickly, the "spill rate" of legit-looking phish is minutes

Defensive Layer (Not Just Training)

DMARC policy: reject on all your domains

URL/DNS filtering at the gateway (block newly-registered domains)

Sandbox scanning of attachments

Crypto-email for executives (vishing/AI-voice is on executives: fake messages from the "CEO")

Report button + quick SOC feedback loop

[← The Psychology of Social Eng...](#)

[Vishing, Smishing & AI-Powered...](#)